



KENYA PRIVACY LAW REVIEW

A RESEARCH PUBLICATION ON PRIVACY, DATA PROTECTION & AI GOVERNANCE

PRACTICE NOTE SERIES

PRACTICE NOTE NO. 001 (2026)

THE ARCHITECTURE OF LAWFUL PROCESSING

*Constitutional Foundations,
Statutory Design, and the Doctrine of
Proportionality under the Data Protection Act, 2019*

AUTHOR

Muchangi Patrick

Advocate of the High Court of Kenya



TECHNOLOGY LAW



DATA PROTECTION



ARTIFICIAL
INTELLIGENCE



REF:

KPLR/PN/001/2026



PUBLISHED:

JULY 2026



RECOMMENDED CITATION

Muchangi Patrick, 'The Architecture of Lawful Processing: Constitutional Foundations, Statutory Design, and the Doctrine of Proportionality under the Data Protection Act, 2019', Kenya Privacy Law Review, Practice Note No. 001 (2026).



KENYA PRIVACY LAW REVIEW

A Research Publication on Privacy, Data Protection & AI Governance

PRACTICE NOTE SERIES · INAUGURAL

PUBLICATION PRACTICE NOTE NO. 001 (2026)

THE ARCHITECTURE OF LAWFUL PROCESSING

Constitutional Foundations, Statutory Design, and the Doctrine of Proportionality under the Data Protection Act, 2019

AUTHOR

Muchangi Patrick

Advocate of the High Court of Kenya

Technology Law · Data Protection · Artificial Intelligence · Cybersecurity

PUBLISHED: JULY 2026

REF: KPLR/PN/001/2026

RECOMMENDED CITATION

Muchangi Patrick, 'The Architecture of Lawful Processing: Constitutional Foundations, Statutory Design, and the Doctrine of Proportionality under the Data Protection Act, 2019', Kenya Privacy Law Review, Practice Note No. 001 (2026).

© 2026 Muchangi Patrick. All rights reserved. This publication is provided for informational purposes only and does not constitute legal advice.

DATA PROTECTION · CONSTITUTIONAL LAW

The Architecture of Lawful Processing

Constitutional Foundations, Statutory Design, and the Doctrine of Proportionality under the Data Protection Act, 2019

AT A GLANCE

- Kenya's data protection regime does not begin with the **Data Protection Act, 2019** (“*the Act*”); it begins with Article 31 of the Constitution, and the Act must be read, at every point of ambiguity, as legislation enacted to give effect to that guarantee, not as a free-standing regulatory code.
- The Act's data protection principles are not a compliance checklist. They are a proportionality framework: each principle operationalises the constitutional balance between an individual's right to privacy and the countervailing interests of the state, the market, and third parties.
- *Nubian Rights Forum v Attorney General* [2020] eKLR, decided before the Act came into force, remains the doctrinal anchor of Kenyan data protection law. It established that a data protection impact assessment is a precondition for high-risk processing, not a retrospective justification.
- ‘*Legitimate interest*’ is the most litigated and least understood lawful basis in the Act. This Note proposes a four-part balancing test, *purpose*, *necessity*, *balancing*, and *safeguards*, derived from the Act's own structure and from comparative doctrine.
- This Note is the doctrinal keystone of the Kenya Privacy Law Review Practice Note series: Practice Notes 002 through 005 each apply, in a specific factual setting, the constitutional and statutory architecture set out here.

I. Introduction: Why a Maiden Note Begins with Foundations

It is tempting, in a jurisdiction as young in its data protection jurisprudence as Kenya, to begin with the practical: **the notice requirements, the registration thresholds, the breach-reporting timelines.** Practice Notes 002 through 005 in this series do exactly that, and deliberately so, employee monitoring, cross-border transfers, AI procurement, and privacy by design are the settings in which data protection law is actually practised, argued, and litigated.

But a practice built entirely on the particular, without a settled account of the general, is brittle. It produces advice that is confident in the easy case and silent in the hard one

— and it is the hard cases, not the easy ones, that end up before the Office of the Data Protection Commissioner's ("ODPC") Complaints and Enforcement division, or before the High Court. This inaugural Practice Note exists to supply that general account: the constitutional guarantee from which Kenyan data protection law descends, the statutory architecture the Data Protection Act, 2019 built on that foundation, and the interpretive method — proportionality — that ties the two together and resolves what the text alone cannot.

The argument that follows is addressed, deliberately, to a wider readership than the compliance officer. It is addressed to the judge asked to weigh a novel claim under the Act for the first time; to the ODPC adjudicator drafting an enforcement notice with no local precedent to cite; to the scholar situating Kenya within the global data protection order; and to the practitioner who must, in the end, translate all of this into a position a client can act on.

II. The Constitutional Guarantee: Article 31 and Its Content

Article 31 of the Constitution of Kenya, 2010 provides that every person has the right to privacy, which includes the right not to have their person, home or property searched; their possessions seized; information relating to their family or private affairs unnecessarily required or revealed; or the privacy of their communications infringed. Nowhere does the Constitution use the phrase “data protection.” The phrase, and the statutory scaffolding that comes with it, is a creature of the Data Protection Act, 2019 — enacted nearly a decade after the Constitution, and expressly framed in its long title as legislation to give effect to Article 31.

That drafting choice matters more than it might first appear. It means that when the Act is silent, ambiguous, or in genuine tension with a competing statute, the interpretive reference point is not the Act's own recitals but Article 31 itself, read together with Article 24 — the general limitation clause, which permits a right to be limited only by law, and only to the extent that the limitation is reasonable and justifiable in an open and democratic society, having regard to the nature of the right, the importance and purpose of the limitation, the nature and extent of the limitation, the need to ensure the right is enjoyed by all, and the relation between the limitation and its purpose, together with the existence of any less restrictive means to achieve that purpose.

The clearest judicial articulation of this relationship predates the Act itself. In *Nubian Rights Forum v Attorney General* [2020] eKLR — the constitutional challenge to the National Integrated Identity Management System (“NIIMS,” popularly known as Huduma Namba) — the High Court was asked to assess the legality of a mass biometric data-collection exercise undertaken before Kenya had a data protection statute at all. The Court did not treat the absence of legislation as licence. It held, in substance, that the government's data-collection programme could not proceed to full roll-out without a comprehensive regulatory framework, including what the judgment described in terms closely tracking a data protection impact assessment, and without adequate safeguards against the risks the collection of sensitive biometric and ethnicorigin data posed — including the specific risk of exclusion and profiling of already marginalised communities.

Nubian Rights Forum is doctrinally significant for this Note in three respects. First, it confirms that Article 31 has independent bite — it does not wait for enabling legislation to become operative. Second, it establishes the impact-assessment-as precondition principle that the Act later codified and that Practice Note No. 004 in this series applies directly to AI procurement. Third, and most importantly for present purposes, it demonstrates the Court's method: not mechanical rule-application, but proportionality analysis — legitimate aim, suitability, necessity, and balancing — applied directly to a privacy claim. That method is this Note's central thesis, and it is developed in Part V below.

III. From Constitution to Statute: The Design of the Data Protection Act, 2019

The Act's structure is best understood not as a list of obligations but as a sequence of institutional and doctrinal choices, each of which answers a question the Constitution leaves open.

A. Institutional design

The Act establishes the Office of the Data Protection Commissioner as an independent office with investigative, enforcement, and standard-setting functions — answering the Constitution's silence on who enforces Article 31 in the data context. The registration regime for data controllers and processors, and the ODPC's power to issue compliance and enforcement notices, give the constitutional right an administrative enforcement track that operates alongside, and typically ahead of, constitutional litigation.

B. The data protection principles

The principles set out in the Act — that processing be lawful, fair and transparent; that data be collected for specified and legitimate purposes and not further processed in a manner incompatible with those purposes; that data be adequate, relevant and limited to what is necessary (data minimisation); that data be accurate and, where necessary, kept up to date; that data be kept in a form permitting identification for no longer than necessary; and that data be processed in a manner ensuring appropriate security, integrity and confidentiality — track the familiar architecture found in comparable data protection statutes internationally. What is easy to miss on a first reading is that each principle is doing constitutional work: purpose limitation and data minimisation are necessity and proportionality by another name; the security and confidentiality principle operationalises the state's positive obligation to protect the right, not merely refrain from infringing it.

C. Lawful bases for processing

The Act permits processing only where the data subject has consented, or where processing is necessary for one of several specified purposes: performance of a contract to which the data subject is party; compliance with a legal obligation; protection of the vital interests of the data subject or another person; performance of a task carried out in the public interest or in the exercise of official authority; or the legitimate interests pursued by the data controller or a third party, except where those interests are overridden by the fundamental rights and freedoms of the data subject.

Of these six grounds, the last — legitimate interest — generates the overwhelming share of difficult advisory questions in practice, precisely because it is the only ground that requires the controller itself to perform, *ex ante*, the proportionality balancing that Article 24 requires of the state *ex post*. Part IV develops a structured framework for that exercise.

D. Data subject rights and cross-border transfer

The Act grants data subjects rights of access, correction, deletion, objection, and restriction, and — as Practice Note No. 003 in this series examines in detail — restricts the transfer of personal data outside Kenya to jurisdictions or arrangements offering appropriate safeguards. Both sets of provisions are, again, statutory instantiations of the constitutional guarantee: the data subject rights give Article 31 a set of enforceable individual remedies, and the transfer regime prevents the guarantee from being circumvented simply by moving the data across a border.

IV. Legitimate Interest and the Architecture of Balancing

No lawful basis in the Act generates as much advisory uncertainty, or as much risk of good-faith error, as legitimate interest. Controllers reach for it as a residual ground when consent is impractical and no other specific ground fits — and in doing so, frequently articulate the “legitimate interest” at a level of generality (“improving our business,” “marketing effectiveness”) that would not survive scrutiny by the ODPC or a court applying Article 24 by analogy. This Note proposes that practitioners test any reliance on legitimate interest against four sequential questions.

- Purpose: Is the interest identifiable, lawful, and articulated with enough specificity that a data subject reading the notice would understand precisely what is being done and why — as opposed to a generic commercial justification that could apply to almost any processing activity?
- Necessity: Is the processing actually necessary to achieve that specific purpose, or would a less intrusive method — aggregation, pseudonymisation, a shorter retention period, a narrower data set — achieve substantially the same result?
- Balancing: Weighed against the data subject's reasonable expectations at the point of collection — not the controller's convenience — does the controller's interest outweigh the impact on the data subject's rights and freedoms? Sensitive categories of data, children's data, and covert or continuous monitoring all shift this balance sharply against the controller.
- Safeguards: Have additional measures — transparency, a meaningful opt-out, retention limits, access controls — been layered onto the processing to reduce its residual impact on the data subject, independent of whether the balancing test alone would succeed?

This four-part test is not found verbatim in the Act. It is, however, a faithful decomposition of what “legitimate interests ... except where such interests are overridden by the fundamental rights and freedoms of the data subject” requires a controller to actually do, and it mirrors the proportionality method the High Court applied directly to Article 31 in *Nubian Rights Forum*. Practice Note No. 002 in this series applies exactly this test to the employee monitoring context, where the tension between an employer's legitimate operational interest and an employee's reasonable expectation of privacy is at its most acute.

V. The Doctrine of Proportionality as the Interpretive Key

The thesis of this Note can be stated simply: the Data Protection Act, 2019 should be read, at every point of genuine ambiguity, through the proportionality method that Article 24 of the Constitution supplies and that Nubian Rights Forum applied — legitimate aim, suitability, necessity, and balancing, together with a live inquiry into whether a less restrictive alternative existed.

This is not merely an academic preference for constitutional purism over statutory literalism. It has three concrete practical consequences. First, it means the ODPC and the courts are not confined to the Act's text when a novel fact pattern arises — the constitutional method fills the gap the statute leaves. Second, it means that compliance built solely around the Act's express requirements, without an underlying proportionality analysis, will systematically underperform in exactly the disputes most likely to attract regulatory or judicial scrutiny — because those are, definitionally, the cases where the text alone does not yield a clear answer. Third, it gives practitioners a common vocabulary with the bench: a submission framed in terms of legitimate aim, necessity, and less restrictive alternatives speaks the same doctrinal language the courts already use for every other qualified right in the Bill of Rights, rather than asking a judge to reason from first principles within an unfamiliar statutory silo.

VI. How This Note Anchors the Series

Each subsequent Practice Note in this series is, on close reading, an application of the architecture set out here to a specific factual domain.

- Practice Note No. 002 (Employee Monitoring) applies the four-part legitimate interest test of Part IV to the employer–employee relationship, where the power imbalance between the parties makes the balancing and safeguards limbs of the test do most of the analytical work.
- Practice Note No. 003 (Cross-Border Data Transfers) applies the same proportionality logic to the Act's transfer regime, treating an “adequate safeguards” determination as itself a necessity-andbalancing exercise rather than a box-ticking comparison of foreign statutes.
- Practice Note No. 004 (Artificial Intelligence Procurement) operationalises the Nubian Rights Forum holding directly: the data protection impact assessment as a precondition for high-risk processing, applied to the procurement of AI systems before, not after, deployment.
- Practice Note No. 005 (Privacy by Design) gives the accountability and dataminimisation principles of Part III their architectural form — building the proportionality analysis into a system's design rather than performing it retrospectively as a compliance exercise.

Read together, the series is intended to demonstrate that Kenyan data protection practice, done well, is not five unrelated technical specialisms. It is one constitutional and doctrinal method, applied five times.

VII. Conclusion

A maiden Practice Note carries a particular obligation: to set a standard the notes that follow it must live up to, and to give a growing body of practitioners, regulators, and judges a shared account of first principles they can return to when a case does not resolve itself by reference to the statutory text alone. Kenya's data protection law is, on this account, neither a transplant of the GDPR nor a free-standing regulatory code. It is a constitutional guarantee, given statutory form, interpreted through a doctrine of proportionality this jurisdiction had already begun to develop before the Act existed. That is the architecture the remainder of this series builds upon.

COMPANION PRACTICE NOTES IN THIS SERIES

- Employee Monitoring: Balancing Employer Oversight and Employee Privacy Rights under the Data Protection Act, 2019 — Practice Note No. 002
- Cross-Border Data Transfers: Legal, Regulatory and Practical Considerations under the Data Protection Act, 2019 — Practice Note No. 003
- Artificial Intelligence Procurement: Legal, Privacy and Governance Considerations for Kenyan Organisations — Practice Note No. 004
- Privacy by Design: Embedding Data Protection into Systems, Products and Processes under the Data Protection Act, 2019 — Practice Note No. 005

RECOMMENDED CITATION

Muchangi Patrick, 'The Architecture of Lawful Processing: Constitutional Foundations, Statutory Design, and the Doctrine of Proportionality under the Data Protection Act, 2019', Kenya Privacy Law Review, Practice Note No. 001 (July 2026).

This publication is issued as KPLR Practice Note No. 001 and bears the publication reference KPLR/PN/001/2026. It is provided for general informational purposes only, is not a substitute for independent legal advice on the facts of any particular matter, and does not create an advocate–client relationship.